

CYBERSECURITY RISK ASSESSMENT

Harbor & Finch CPAs

Aligned to the NIST Cybersecurity Framework v1.1

Risk Identification, Analysis, and Treatment Recommendations

Prepared by: Jakkula Rama Venkata Prasad Vishnu Prathap

Role: Cybersecurity Risk Analyst

Date: May 2026

Classification: Fictitious company for risk assessment practice

1. Executive Summary

This report presents the findings of a cybersecurity risk assessment of Harbor & Finch CPAs, a 28-person public accounting firm handling tax preparation, audit, and advisory services. The firm stores significant volumes of regulated and sensitive client data, including Social Security Numbers, Employer Identification Numbers, banking details, and audit working papers for clients in scope of the Sarbanes-Oxley Act.

The assessment was conducted in accordance with the NIST Cybersecurity Framework v1.1 and applied a 5x5 likelihood-impact methodology to identify, analyze, and prioritize ten significant risks across the Identify, Protect, Detect, Respond, and Recover functions.

This is a fictitious company, and the risks have been made to familiarize and practice making risk assessments.

Key Findings

- Six of ten identified risks were rated Critical, indicating immediate executive attention is required.
- The most severe gaps are concentrated in the Protect function: absence of multi-factor authentication, lack of mobile device management, and no business email compromise (BEC) controls.
- The firm has no detection or response capability. A compromise today would likely go undiscovered, and there is no plan to respond if one were detected.
- Regulatory exposure includes IRS Publication 4557, the FTC Safeguards Rule (GLBA), and state breach notification laws. Several findings represent direct non-compliance.

Risk Posture Summary

Aggregate risk exposure is assessed as **HIGH**. The firm operates with a security posture typical of pre-incident small professional services organizations. Without remediation, the likelihood of a material security incident within the next twelve months is assessed as Likely (4 of 5).

Recommended Next Steps

- **Immediate (0–30 days):** Deploy MFA across Microsoft 365 and tax-preparation platforms; institute wire-transfer callback verification.
- **Short term (30–90 days):** Implement security awareness training, MDM for BYOD devices, and a documented incident response plan.
- **Medium term (90–180 days):** Establish centralized logging, formalize MSP access governance, and develop an asset inventory and data classification scheme.

2. Scope and Methodology

2.1 Scope

This assessment covers the people, processes, and technology that store, transmit, or process client and firm data at Harbor & Finch CPAs, including:

- Microsoft 365 tenant (email, SharePoint, OneDrive, Teams)
- Tax preparation platforms (Intuit ProConnect, Lacerte) and QuickBooks Online
- On-premises file server hosting archived audit working papers
- Firm-issued laptops and partner-owned (BYOD) endpoints
- Third-party managed service provider relationship
- Administrative processes including onboarding, offboarding, wire-transfer authorization, and vendor management

Out of scope: physical security of the building (covered under a separate facilities review) and client-owned systems.

2.2 Methodology

The assessment followed a four-phase approach:

- **Identify:** Documented the firm's assets, data flows, regulatory obligations, and current control environment through interview and document review.
- **Analyze:** Mapped identified risks to NIST CSF subcategories and scored each on likelihood and impact.
- **Prioritize:** Ranked risks by composite score and produced a heatmap to support executive decision-making.
- **Recommend:** Proposed treatment options (mitigate, transfer, accept, avoid) and associated controls aligned to NIST CSF.

2.3 Risk Scoring Scales

Risks are scored on a 5x5 matrix. The composite risk score is the product of likelihood and impact.

Likelihood Scale

Score	Rating	Definition
1	Rare	Unlikely to occur within five years
2	Unlikely	Possible but improbable within two to three years
3	Possible	Could reasonably occur within twelve months
4	Likely	Expected to occur within twelve months
5	Almost Certain	Expected to occur within months; ongoing exposure

Impact Scale

Score	Rating	Definition
1	Negligible	Minor disruption; loss under USD 5,000
2	Minor	Loss of USD 5,000 to USD 25,000; no regulatory exposure
3	Moderate	Loss of USD 25,000 to USD 100,000; some client impact; minor regulatory notice
4	Major	Loss of USD 100,000 to USD 500,000; significant client impact; regulatory penalties; reputational damage
5	Severe	Loss above USD 500,000; mass client breach; IRS sanctions; business viability threatened

Risk Rating Bands

Score Range	Rating	Treatment Expectation
16 – 25	Critical	Immediate mitigation required; executive notification
10 – 15	High	Mitigation within 90 days; tracked monthly
5 – 9	Medium	Mitigation within 180 days; tracked quarterly
1 – 4	Low	Accept or monitor; review annually

3. Organizational Context

3.1 Business Overview

Harbor & Finch CPAs is a 28-person public accounting firm operating from a single office. The firm provides tax preparation, audit and assurance, bookkeeping, payroll, and financial advisory services to approximately 450 small-to-mid business clients and 1,200 individual tax clients. Annual revenue is approximately USD 4.2 million.

3.2 Data Inventory

The firm holds significant volumes of regulated and sensitive information, including:

- Client Social Security Numbers and Employer Identification Numbers
- Client bank account and routing numbers
- Tax returns, financial statements, and supporting documentation
- Audit working papers for clients reporting under the Sarbanes-Oxley Act
- Payroll data including employee SSNs and direct-deposit information
- Internal HR records and firm financial data

3.3 Technology Environment

- Microsoft 365 (email, SharePoint, OneDrive, Teams)
- Intuit ProConnect / Lacerte for tax preparation
- QuickBooks Online for bookkeeping
- On-premises Windows file server for archived working papers
- Twenty-four firm-issued Windows laptops and four partner-owned (BYOD) devices
- No dedicated security personnel; IT operations outsourced to a part-time managed service provider

3.4 Regulatory and Contractual Obligations

- **IRS Publication 4557:** Safeguards for taxpayer data. Mandatory written information security plan.
- **FTC Safeguards Rule (GLBA):** Applies to firms providing financial services; requires designated qualified individual, written program, and risk assessment.
- **State data breach notification laws:** All 50 U.S. states impose notification timelines following discovery of a breach involving personal information.

- **SOX (indirect):** Audit clients reporting under SOX expect their auditor to maintain commensurate information security controls.

4. Risk Register

The following ten risks were identified and ranked by composite score. Detailed analysis and recommended controls for each risk follow in Section 6.

ID	Risk	NIST	L	I	Score	Rating
R-04	No MFA on M365 or tax software	PROTECT	5	5	25	Critical
R-06	Insufficient security awareness training	PROTECT	5	4	20	Critical
R-08	BEC — no wire verification process	PROTECT	4	5	20	Critical
R-03	Weak access controls on file server	PROTECT	4	4	16	Critical
R-05	BYOD devices with no MDM	PROTECT	4	4	16	Critical
R-10	No incident response plan	RESPON	4	4	16	Critical
R-07	Ungoverned MSP third-party access	PROTECT	3	5	15	High
R-09	No centralized logging or SIEM	DETECT	5	3	15	High
R-02	No data classification scheme	IDENTIFY	4	3	12	High
R-01	No formal asset inventory	IDENTIF	5	2	10	High

5. Risk Heatmap

The heatmap below plots each identified risk by its likelihood (vertical axis) and impact (horizontal axis). Cell color indicates the composite risk rating. Six of ten risks fall in the Critical band.

	Impact 1	Impact 2	Impact 3	Impact 4	Impact 5	
Likelihood 5		R-01	R-09	R-06	R-04	
Likelihood 4			R-02	R-03, R-05, R-10	R-08	
Likelihood 3					R-07	
Likelihood 2						
Likelihood 1						

Legend

Critical	Composite score 16 – 25. Immediate mitigation required.
High	Composite score 10 – 15. Mitigation within 90 days.
Medium	Composite score 5 – 9. Mitigation within 180 days.
Low	Composite score 1 – 4. Accept or monitor.

6. Detailed Risk Analysis and Recommended Controls

This section presents each identified risk in detail, including its NIST CSF mapping, scoring rationale, and recommended controls. Risks are presented in order of composite score, highest first.

6.1 R-04 — No multi-factor authentication on M365 or tax software

NIST CSF Function	PROTECT
NIST Subcategories	PR.AC-1, PR.AC-7
Likelihood	5 of 5
Impact	5 of 5
Composite Score	25
Rating	Critical

Risk Description. Microsoft 365 (email, SharePoint, OneDrive) and Intuit ProConnect/Lacerte are accessible with password only. Email accounts contain W-2s, SSNs, and full client correspondence. Credential reuse and phishing are likely attack vectors.

Recommended Control. Enforce MFA on all Microsoft 365 accounts and tax-preparation platforms within 30 days. Use phishing-resistant methods (authenticator app or FIDO2) rather than SMS where supported.

6.2 R-06 — Insufficient security awareness training

NIST CSF Function	PROTECT
NIST Subcategories	PR.AT-1, PR.AT-2
Likelihood	5 of 5
Impact	4 of 5
Composite Score	20
Rating	Critical

Risk Description. Staff receive no formal phishing or social-engineering training. Accounting firms are top phishing targets during tax season (January through April), with attackers impersonating the IRS, clients, and tax-software vendors.

Recommended Control. Implement quarterly security awareness training with simulated phishing campaigns. Increase frequency to monthly during tax season. Track click rates and provide remedial training for high-risk users.

6.3 R-08 — Business Email Compromise — no wire verification process

NIST CSF Function	PROTECT
NIST Subcategories	PR.DS-2, PR.IP-1
Likelihood	4 of 5
Impact	5 of 5
Composite Score	20
Rating	Critical

Risk Description. Partners authorize client wire transfers via email with no out-of-band callback verification. BEC fraud against accounting firms averages over USD 130,000 per incident according to FBI IC3 reporting.

Recommended Control. Mandate verbal callback verification using a known phone number for any wire transfer instruction received by email. Enable Microsoft 365 anti-spoofing (DMARC, DKIM, SPF) and impersonation-protection policies.

6.4 R-03 — Weak access controls on file server

NIST CSF Function	PROTECT
NIST Subcategories	PR.AC-4, PR.AC-6
Likelihood	4 of 5
Impact	4 of 5
Composite Score	16
Rating	Critical

Risk Description. The on-premises file server hosting archived working papers grants broad “all staff” read access. A junior accountant can access partner-level client files. No least-privilege model is enforced.

Recommended Control. Implement role-based access control (RBAC) with engagement-level folder permissions. Conduct quarterly access reviews. Restrict access by client engagement rather than by job title.

6.5 R-05 — BYOD devices with no mobile device management

NIST CSF Function	PROTECT
NIST Subcategories	PR.AC-3, PR.DS-1
Likelihood	4 of 5
Impact	4 of 5
Composite Score	16
Rating	Critical

Risk Description. Four partner-owned laptops and mobile devices access client data with no enforced disk encryption, no screen-lock requirement, no remote-wipe capability, and no separation of personal and firm data.

Recommended Control. Adopt an MDM solution (e.g., Microsoft Intune) to enforce encryption, screen lock, remote wipe, and a managed app container for personal devices accessing firm data. Formalize a BYOD policy and acceptable use agreement.

6.6 R-10 — No incident response plan

NIST CSF Function	RESPOND
NIST Subcategories	RS.RP-1, RS.CO-1, RS.CO-4
Likelihood	4 of 5
Impact	4 of 5
Composite Score	16
Rating	Critical

Risk Description. No documented incident response playbook, no defined roles, and no notification procedures for the IRS, state regulators, or affected clients in the event of a breach. Regulatory clocks (e.g., state breach laws) may be missed.

Recommended Control. Develop and approve a written incident response plan aligned with NIST SP 800-61. Define roles, escalation paths, regulatory notification timelines (IRS, state AGs, FTC under GLBA), and engage a forensic firm on retainer. Conduct an annual tabletop exercise.

6.7 R-07 — Ungoverned MSP third-party access

NIST CSF Function	PROTECT
NIST Subcategories	ID.SC-2, ID.SC-3, PR.AC-1
Likelihood	3 of 5
Impact	5 of 5
Composite Score	15
Rating	High

Risk Description. The part-time managed service provider holds domain administrator credentials with no access reviews, no logging of administrative actions, no formal data-handling clauses in the contract, and no requirement for MFA on their accounts.

Recommended Control. Move MSP accounts to a just-in-time privileged access model. Require MFA, log all administrative sessions, and execute a vendor agreement covering data handling, breach notification, and right-to-audit. Conduct annual vendor risk reviews.

6.8 R-09 — No centralized logging or SIEM

NIST CSF Function	DETECT
NIST Subcategories	DE.CM-1, DE.CM-7, DE.AE-3
Likelihood	5 of 5
Impact	3 of 5
Composite Score	15
Rating	High

Risk Description. No security information and event management (SIEM) capability or even basic log review is in place. A compromised account could exfiltrate client data for weeks or months without detection.

Recommended Control. Deploy a lightweight SIEM or managed detection and response (MDR) service. At minimum, enable Microsoft 365 audit logging, ingest authentication logs, and configure alerts for impossible travel, mass downloads, and admin actions.

6.9 R-02 — No data classification scheme

NIST CSF Function	IDENTIFY
NIST Subcategories	ID.AM-5, ID.GV-1
Likelihood	4 of 5
Impact	3 of 5
Composite Score	12
Rating	High

Risk Description. Client SSNs, tax returns, and audit working papers are stored alongside general business files with no labeling, handling rules, or retention policy. Staff cannot reliably distinguish sensitive data from routine documents.

Recommended Control. Develop a data classification policy with at least three tiers (Public, Internal, Confidential). Apply labels to all client-data repositories and train staff on handling requirements per tier.

6.10 R-01 — No formal asset inventory

NIST CSF Function	IDENTIFY
NIST Subcategories	ID.AM-1, ID.AM-2
Likelihood	5 of 5
Impact	2 of 5
Composite Score	10
Rating	High

Risk Description. The firm does not maintain a documented inventory of laptops, mobile devices, servers, or cloud accounts that store or process client data. Asset ownership and lifecycle status are tracked informally.

Recommended Control. Implement and maintain a centralized asset inventory covering all hardware, software, and cloud services. Assign an owner to each asset and review quarterly.

7. Treatment Roadmap

Recommended treatment is grouped into three time horizons. Costs are notional and intended to support executive prioritization.

Horizon	Action	Risks	Effort
0–30 days	Enforce MFA on Microsoft 365 and tax-preparation platforms	R-04	Low
0–30 days	Institute mandatory verbal callback verification for all wire-transfer instructions	R-08	Low
0–30 days	Restrict file-server share permissions to engagement-level RBAC	R-03	Medium
30–90 days	Roll out security awareness training and simulated phishing	R-06	Medium
30–90 days	Deploy MDM (Microsoft Intune) and a BYOD policy	R-05	Medium
30–90 days	Develop and approve a written incident response plan; engage forensic firm on retainer	R-10	Medium
90–180 days	Deploy SIEM or managed detection and response (MDR) service	R-09	High
90–180 days	Formalize MSP access governance: just-in-time admin, MFA, logging, contract	R-07	Medium
90–180 days	Build asset inventory and data classification scheme	R-01, R-02	Medium

8. Conclusion

Harbor & Finch CPAs operates with an aggregate risk posture rated HIGH, reflecting a control environment typical of professional services firms that have not yet experienced a material security incident. The findings in this report do not indicate negligence; they reflect the natural gap between the firm's growing exposure to sensitive client data and the maturity of its security program.

Six of the ten identified risks are rated Critical and warrant immediate executive attention. The treatment roadmap in Section 7 prioritizes low-cost, high-impact actions (MFA, wire-transfer verification, file-server permissions) in the first thirty days. Sustained progress over six months would move the firm from a reactive posture to a baseline aligned with the NIST Cybersecurity Framework and the FTC Safeguards Rule.

This assessment should be refreshed annually, or sooner if there is a material change to the firm's technology environment, regulatory obligations, or client portfolio.

Appendix A — NIST CSF Function Coverage

NIST Function	Risks	Coverage
IDENTIFY	R-01, R-02	Asset management, data classification
PROTECT	R-03, R-04, R-05, R-06, R-07, R-08	Access control, awareness training, data security, third-party governance
DETECT	R-09	Continuous monitoring, anomalies and events
RESPOND	R-10	Response planning, communications
RECOVER	<i>(out of scope this cycle)</i>	Recommended for next assessment

Appendix B — Glossary

- **BEC:** Business Email Compromise. Fraud scheme in which attackers impersonate executives, vendors, or clients via email to redirect payments.
- **GLBA:** Gramm-Leach-Bliley Act. U.S. law including the FTC Safeguards Rule, which requires financial institutions (including accounting firms providing financial services) to protect customer information.
- **MDM:** Mobile Device Management. Software that enforces security policies on managed and BYOD endpoints.

- **MFA:** Multi-Factor Authentication. Requires two or more independent factors to authenticate.
- **MSP:** Managed Service Provider. Third-party vendor providing outsourced IT services.
- **NIST CSF:** National Institute of Standards and Technology Cybersecurity Framework. Voluntary framework structured around five functions: Identify, Protect, Detect, Respond, Recover.
- **SIEM:** Security Information and Event Management. Centralized log collection and alerting platform.
- **SOX:** Sarbanes-Oxley Act. U.S. law imposing internal-control requirements on public companies and, by extension, their auditors.